

The background of the image features a dark blue gradient on the left, transitioning into a large, vibrant, abstract shape on the right. This shape is composed of overlapping curved segments in shades of orange, pink, and purple, creating a dynamic and modern visual effect.

AWS re:Invent

NOV. 27 – DEC. 1, 2023 | LAS VEGAS, NV

SEC321 - R

Did it really happen? Set your eyes on the perimeter with AWS WAF

Vaibhav Agarwal

Principal Product Manager
AWS WAF

Tzoori Tamam

Principal Solutions Architect Specialist
AWS Edge Services



© 2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

What to expect of the next 60 minutes?



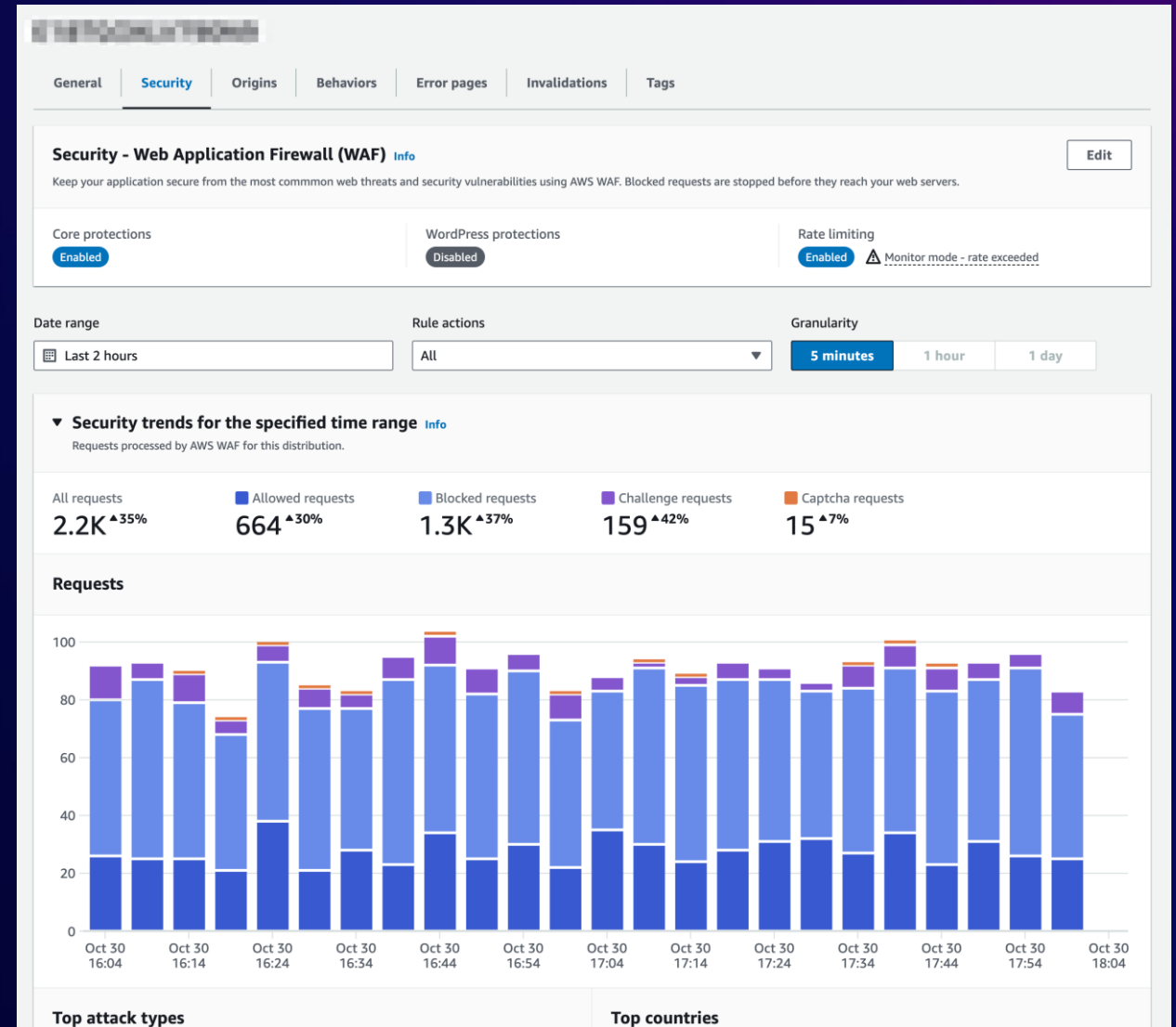
- What is a 300 level talk?
- What is a chalk-talk?
- Topics to be covered (also) include:
 - Why is visibility important to you?
 - Metrics vs. Logs
 - Dashboarding – why, what, and where
 - Best practices
- Get ready for “show of hands” questions

AWS WAF visibility 101



New – AWS WAF built-in dashboard

- Accessible from CloudFront and from AWS WAF consoles
- Provides a high-level visibility into top rules and contributors
- Built-in dashboards for **Fraud Control** and **Bot Control** activities



AWS Shield Advanced visibility 101

- CloudWatch Metrics
 - Number of attacks/resource
 - Attack vectors/resource
 - Mitigation action/resource
- Shield Advanced Dashboard
 - Ongoing events
 - Event details
 - Detected and Mitigation
 - Top Contributors
- Global Threat Dashboard

Global threat dashboard across all AWS customers

The following is a sampling of the most significant attacks that AWS is monitoring and mitigating for customers on Amazon EC2, Amazon CloudFront, Elastic Load Balancing, and Amazon Route 53.

Select global threat period

Last Two Weeks

Attack frequency map



Last two weeks summary

302 Mpps Largest packet attack

776 Gbps Largest bit rate

SYN flood Most common vector

Normal Threat level

219,617 Total number of attacks

Use cases for perimeter protection visibility

What just happened?

Increased request rate? Blocking rate? Certain rules?
Geos? More bots? More log-ins?

Was it the right thing to happen?

Is it worth investigating? True or false positive?

Why are we using it?

Are AWS WAF and Shield alerting on the right things?
Were we just allowing stuff in before?

Can we do better?

Can we tune our rate limits? Can we add more controls?
Can we switch from Count to Block?

Did something change?

Are these new behaviors because we changed something?
AWS changed something? Our clients change something?

Using CloudWatch Metrics – Pointers

- Each web ACL, rule (managed or not), label, rule group, and action has a separate metric – What can they be used for?
- What are your noise levels?
- Who and when do you alert?
- Alerts can also drive automations
- Create meaningful dashboard for different personas

Using AWS WAF Logs

- Logs contain all relevant WAF data and request data
- Used for:
 - Dig deeper into metrics
 - Troubleshooting
- Store logs where you can consume them most conveniently
- Logs can be redacted and filtered
- What is your retention policy?



AWS WAF
logs fields

Best practices and how-to

- Cost optimization
- Event aggregation
 - Through queries
 - With dashboards
- Tracking false positives
- Managing rate-based rules

Filter requirement
Criteria for a request to be a match for the filter conditions.

☒ Match all of the filter conditions
☐ Match at least one of the filter conditions

Filter conditions
Select the filtering criteria.

Condition type
Request has label ▼

Condition value
Omit-From-Log X Remove

Enter a fully qualified label. For example, aws:aws:managed:aws:linux-os:LFI_Header. [Learn More](#)

Add condition

Filter behavior
Select the action to take for requests that match the filter criteria.

☐ Keep in logs
☒ Drop from logs

AWS WAF Log filtering

```
fields httpRequest.clientIp
| stats count(*) as requestCount by httpRequest.clientIp
| sort requestCount desc
| filter @message like "CrossSiteScripting_Body"
```

```
fields @message
| stats count_distinct(httpRequest.clientIp) as uniqueIPs
| filter @message like "SignalNonBrowserUserAgent"
| limit 1000
```

Investigating false positives

Additional resources (pull out your phones now)



Visualize AWS WAF logs
with an Amazon
CloudWatch dashboard



Analyzing AWS WAF
Logs in Amazon
CloudWatch Logs



Deploy a dashboard for
AWS WAF with
minimal effort



Query AWS WAF Logs
with Athena

Additional² resources (keep your phones out)



Analyzing AWS WAF logs
using Amazon CloudWatch
Logs Insights and Contributor
Insights (YouTube 7:00 mins)



Security Dashboard
blog

Thank you!

Vaibhav Agarwal

Tzoori Tamam



Please complete the session
survey in the mobile app

